ShiftSense — Security, Administration and Integrations

Version 1.0 · October 2026.

Contents

- 1. Security model
- 2. Roles and permissions
- Workflow: authentication and account lifecycle
- Workflow: administration and audit
- 3. Integrations
- 4. Data handling

1. Security model

Control	Implementation
Authentication	Password (PBKDF2-SHA256, 600,000 iterations, random salt) and/or OIDC single sign-on; break-glass account in SSO mode
Password policy	≥ 12 characters, 3 of 4 kinds, not name/username, not a common password; forced change of temporary passwords
Brute force	5 failed attempts → 15-minute lock; every attempt audited (never the password)
Sessions	Idle sign-out after 30 minutes; the stored account is re-read on every action
Authorisation	Server-side in `services.py` for every action: role permission, own team, own record, no self-approval
Separation of duties	Second HR user confirms separations and verifies balances; Ops approves contracts; Admin has no operational decisions
Restricted data	Sick-leave details, balances, absence flags and restricted cases visible only to HR (cases: caseworker and Senior HR)
Audit	Append-only `audit_log` (database trigger refuses UPDATE/DELETE), SHA-256 hash chain verified by the health check
Secrets	From the environment or `.streamlit/secrets.toml` only; never stored, logged, exported or shown
Transport	HTTPS through Caddy (automatic certificate) in the Docker stack; PostgreSQL has no public port
Uploads	Photos: type, size, dimensions, decodable; re-encoded and metadata stripped. Imports: validated, path traversal refused
Privacy	Emails masked in tables, logs and exports; verification codes stored only as hashes (30-minute expiry)
Demo isolation	Demo scenario cannot change live data (separate slot and run id)

Known gaps: no external penetration test; SSO not yet run against a real identity provider; multi-server deployment untested; retention periods not set (HR-08).

2. Roles and permissions

The complete matrix is in `supporting/governance/role-permission-matrix.xlsx`: role permissions, every server action × role (asserted by `tests/test_matrix.py`), screens by role and data visibility.

Role permissions as configured in `config/users.yaml` (Team Lead permissions apply to their own team only; Senior HR is an extra permission on an HR account):

Permission	Admin	Analyst	Team Lead	Ops	HR	Agent
`all_teams`	✓	✓		✓	✓	
`approve_data`				✓		
`approve_requests`			✓	✓		
`decide_fix`			✓			
`escalate_risk`		✓				
`governance`	✓					
`import`		✓				
`live_clock`		✓				
`manage_accounts`	✓					
`manage_data`		✓				
`manage_demo`		✓				
`manage_people`					✓	
`manage_service_levels`				✓		
`message`			✓	✓		✓
`ops_decide`				✓		
`own_preferences`						✓
`propose_data`			✓			
`propose_governance_rules`	✓					
`replan`		✓				
`report_absence`			✓			
`report_self`						✓
`report_situation`		✓	✓	✓		
`report_spike`				✓		
`request_leave`						✓
`run_clock`		✓				
`send_reminder`			✓			
`view_audit`	✓			✓		

Workflow: authentication and account lifecycle

Owner: Admin. Implementation: `shiftsense/security.py`, `shiftsense/auth.py`, `shiftsense/accounts.py`, `views/login.py`.

Sign-in modes (`SHIFTSENSE_AUTH`)

- `password` (default): username and password.
- `sso`: OIDC single sign-on (Microsoft Entra, Okta, Google) via Streamlit `st.login`. A person gets in only when one **active** ShiftSense account has the same email; the role is always ShiftSense's, never the

identity provider's.
- `both`: either. `SHIFTSENSE_BREAKGLASS` keeps one emergency password account when SSO is the only mode.

Password rules

- Stored as PBKDF2-SHA256, 600,000 iterations, random salt per person; older hashes upgrade at the next sign-in.
- At least 12 characters, 3 of 4 character kinds, not the name or username, not a common password.
- 5 wrong attempts lock the account for 15 minutes. Idle sign-out after 30 minutes. All configurable.
- Every sign-in attempt is audited; the password never is.

Lifecycle

State / event	Who	Effect
Create	Admin	Temporary password; must be changed at first sign-in
Change own password	Anyone (sidebar → Password)	Policy enforced
Reset / unlock	Admin (reason required)	New temporary password / lock cleared; audited
Role or team change	Admin	The next action re-reads the stored account, so old permissions stop at once
Senior HR permission	Admin grants to an HR account (reason)	`accounts.extra_permissions`; counts only for the HR role
Deactivate	Admin, or automatically at 00:00 Asia/Kolkata after a confirmed separation's last working day	Next action refused; verification codes revoked
Reactivate	Admin, or rescinding the separation that deactivated it	

Demo accounts and their published passwords exist only for the demonstration. **Change or remove them before a pilot**; the health check fails in pilot mode while a demo password is still in use.

Workflow: administration and audit

Owner: Admin (oversight only: no operational decisions). Implementation: `comms.audit`, `timeline.py`, `views/admin.py`.

- **Accounts:** create, reset, unlock, deactivate, role/team change, Senior HR grant; all with reasons, all audited.
- **Governance:** scans for discrepancy signals (thresholds in `config/policy.yaml` → `governance`: approval-rate gaps between agents of one team lead, approvals that left the team short, repeated overtime, repeated swap pairs, repeated overrides); signals for review, not proof;, cases with states Flagged → Under Review → Explanation Requested / Referred to Operations → Action Required → Resolved → Closed (or Dismissed). Every scan is audited, including empty ones.
- **Audit trail:** one row per action in `audit_log` with actor, role, action, target, details. Rows are SHA-256 hash-chained and append-only (a database trigger refuses UPDATE/DELETE). `python -m shiftsense.health` verifies the chain. Audit rows are never deleted.
- **History:** `services.history` / `history_export` gives the shared event → state → recommendation → decision → outcome timeline, role-scoped.
- **Decision log:** every team-lead and Ops decision with its mandatory reason.
- **System status:** health, backups, email relay check (Admin → People & accounts).

3. Integrations

Integration	Direction	How	Configuration	Status
Drop folder	in	files in `data/inbox/<kind>/` (employees, contracts, leave, volumes, attendance, leave_balances, photos)	`scripts/stage_drop_folder.sh` or the app	Built
Excel / CSV / paste / typed text	in	Data hub and HR screens	—	Built
Email (SMTP)	out	notification copies, test email, health alerts	`SHIFTSENSE_EMAIL=smtp`, `SMTP_*`	Built; needs a relay
Single sign-on (OIDC)	in	Streamlit `st.login`	`.streamlit/secrets.toml` `[auth]`, `SHIFTSENSE_AUTH`	Built; needs an identity provider
AI provider (Anthropic)	out	explanations and import help only, never decisions	`ANTHROPIC_API_KEY`, `SHIFTSENSE_AI*`	Optional
PostgreSQL	storage	`SHIFTSENSE_DATABASE_URL`	Docker stack	Built and tested
Exports	out	Excel, CSV, calendar (.ics), print HTML	role-scoped	Built

Single sign-on setup. Register ShiftSense as an OIDC web application with the identity provider (redirect URI `https://<domain>/oauth2callback`). Put the client ID, secret and server metadata URL in the `[auth]` block of `.streamlit/secrets.toml` (see `secrets.toml.example`), set `SHIFTSENSE_AUTH=sso` (or `both`), and create a ShiftSense account for each person with the same email. The role always comes from ShiftSense.

Email setup. Set `SHIFTSENSE_EMAIL=smtp`, `SMTP_HOST`, `SMTP_PORT`, `SMTP_USER`, `SMTP_PASSWORD`, `SMTP_TLS` and `SHIFTSENSE_EMAIL_FROM`. Admin → Accounts & access → *Email relay check* sends one test message; "accepted by relay" is not proof of delivery, so check the inbox.

AI. Optional. `ANTHROPIC_API_KEY` enables it; `SHIFTSENSE_AI=off` disables it; `SHIFTSENSE_AI_CONVERT` controls import help (`nonpersonal` by default). Personal data is not sent by default.

4. Data handling

Register of every table, its personal data and current handling: `supporting/governance/retention-and-data-handling-register.xlsx`. Backups contain accounts and contact details and must be stored as confidential.